InChi Pilot Gateway — Backend API & Data Specification

Target: Internal Researchers, Mentors & Technical Evaluators

Author: Abhishek Kumar (Backend & Access-Control)

Version: v0.1.0 Baseline (Week 1 Implemented)

This report defines the exact data payloads, types, and server-side behaviors for the 100% operational backend endpoints implemented for the **InChi Pilot Gateway**. All access rules are strictly enforced server-side via a centralized zero-trust policy.

1. Global Standards & Error Contract

Every non-2xx response across the entire backend guarantees the following structured JSON schema. Stack traces and internal secrets are strictly prevented from leaking.

Field	Type	Description & Example
`code`	`string`	Machine-readable error identifier (e.g. `"not_authenticated"`, `"permission_denied"`, `"validation_error"`).
`message`	`string`	Human-readable explanation of why the action was rejected.
`field_errors`	`object<string, list>`	Key-value map containing exact field-level validation errors (e.g. `{"email": ["Enter a valid email address."]}`).
`correlation_id`	`string (UUID)`	Unique request tracking UUID injected by middleware for cross-service log tracing (`X-Correlation-ID`).

2. Authentication & Session Endpoints

GET `/api/v1/auth/csrf/` **PUBLIC**

Bootstraps the CSRF cookie for browser clients (Next.js) before state-changing write requests.

Request: No payload or query parameters required.
Response (HTTP 200 OK):

```
{ "detail": "CSRF cookie set." }
```

> **Server Behavior:** Decorated with `@ensure_csrf_cookie`. Injects a set-cookie header: `csrftoken=<token>; Path=/; SameSite=Lax`. The client reads this cookie and transmits its value inside the `X-CSRFToken` header for subsequent POST/PUT/PATCH/DELETE calls.

POST `/api/v1/auth/login/` PUBLIC (CSRF REQUIRED)

Authenticates credentials, establishes an active session, and rotates security tokens.

Request Headers: `X-CSRFToken: <token>`, `Content-Type: application/json`

Field	Type	Requirement	Description & Rules
`email`	`string`	Required	User email address (normalized to lowercase, whitespace stripped).
`password`	`string`	Required	Raw password (never logged or exposed).

Success Response (HTTP 200 OK):

```
{
  "message": "Login successful.",
  "user": {
    "id": "e6e5f83f-5edd-48c0-bbce-d37bebc52c6f",
    "email": "analyst@bncs.local",
    "first_name": "Aarav",
    "last_name": "Sharma",
    "role": "commercial_analyst",
    "role_display": "Commercial Analyst",
    "is_active": true,
    "is_verified": true,
    "is_staff": false,
    "date_joined": "2026-10-29T12:00:00Z",
    "last_login": "2026-10-29T13:45:00Z",
    "version": 1
  }
}
```

Server Behavior & Protection:

- Decorated with `@csrf_protect` to enforce anti-forgery tokens on public logins.
- On successful credential verification, calls Django `login()`, automatically rotating both the session key and CSRF token to prevent session fixation attacks.
- If credentials fail or user is deactivated, returns HTTP 400 with a generic `"Invalid email or password."` message (prevents account enumeration).

GET `/api/v1/auth/me/` AUTHENTICATED (ALL ROLES)

Returns profile, identity, and role metadata for the currently active session.

Request Headers: Session cookie (`sessionid=<id>`)
Success Response (HTTP 200 OK): Returns User object identical to login schema.
Failure Response (HTTP 401 Unauthorized):

```
{
  "code": "not_authenticated",
  "message": "Authentication credentials were not provided or are invalid.",
  "field_errors": {},
  "correlation_id": "a90b4cf2-..."
}
```

Server Behavior: Consumed by frontend route guards (Priyanka) to dynamically display authorized navigation panels without exposing business logic to the client.

POST `/api/v1/auth/logout/` **AUTHENTICATED (ALL ROLES)**

Flushes server-side session data and invalidates client session cookies.

Success Response (HTTP 200 OK):

```
{ "detail": "Logged out successfully." }
```

> **Server Behavior:** Destroys active session record in database; sets `sessionid` cookie with `Max-Age=0`.

3. User Onboarding & Account Verification Endpoints

POST `/api/v1/auth/register/` **PUBLIC / SELF-SERVICE ONBOARDING**

Registers a new internal team member and issues a dedicated account verification token.

Field	Type	Requirement	Validation & Constraints
`email`	`string (email)`	Required	Unique email format, max 254 chars. Rejects duplicates with HTTP 400.
`password`	`string`	Required	Min 8 characters, validated against Django password strength validators.
`first_name`	`string`	Optional	Max 150 chars. Default empty.
`last_name`	`string`	Optional	Max 150 chars. Default empty.
`role`	`string`	Optional	Must match exact choice: `platform_admin`, `commercial_analyst`, or `reviewer`. Defaults to `commercial_analyst`.

Success Response (HTTP 201 Created):

```
{
  "message": "User registered successfully. Please complete verification.",
  "user": {
    "id": "78b4a112-9c22-482d-8f20-fa728c312741",
    "email": "new.member@bncs.local",
    "role": "commercial_analyst",
    "role_display": "Commercial Analyst",
    "is_active": true,
    "is_verified": false
  },
  "verification_token": "f2905b63-8a32-4752-9ef8-e160e90c6792"
}
```

> **Server Behavior:** Creates user record with `is_verified=False` and generates a cryptographically random UUID v4 `verification_token`.

POST `/api/v1/auth/verify/` PUBLIC

Activates and verifies an unverified internal account using the issued token.

Field	Type	Requirement	Validation & Rules
`email`	`string (email)`	Required	Email associated with the unverified account.
`token`	`string`	Required	Verification token received upon registration.

Success Response (HTTP 200 OK):

```
{
  "message": "Account successfully verified. You may now log in.",
  "user": {
    "id": "78b4a112-9c22-482d-8f20-fa728c312741",
    "email": "new.member@bncs.local",
    "is_verified": true
  }
}
```

> **Server Behavior:** Validates token match. On success, transitions `is_verified = True`, clears `verification_token = null` (single-use token protection), and increments optimistic concurrency `version`.

GET `/api/v1/auth/verify/status/?email=<address>` PUBLIC

Inspects the verification state of a given email account.

Query Parameter: `email` (string, required)

Success Response (HTTP 200 OK):

```
{
  "email": "new.member@bncs.local",
  "is_verified": true,
  "is_active": true
}
```

4. Role-Based User Administration (Platform Admin Only)

GET `/api/v1/auth/users/` **PLATFORM ADMIN ONLY**

Returns a paginated roster of all internal BNCS platform users.

Authorization: Rejects Commercial Analyst and Reviewer roles with HTTP 403 Forbidden.
Success Response (HTTP 200 OK):


```
{
  "count": 4,
  "next": null,
  "previous": null,
  "results": [
    {
      "id": "e6e5f83f-5edd-48c0-bbce-d37bebc52c6f",
      "email": "admin@bncs.local",
      "role": "platform_admin",
      "role_display": "Platform Administrator",
      "is_active": true,
      "is_verified": true,
      "is_staff": true,
      "date_joined": "2026-10-29T10:00:00Z",
      "version": 1
    }
  ]
}
```


POST `/api/v1/auth/users/{id}/deactivate/` **PLATFORM ADMIN ONLY**

Soft-deactivates an internal user account, revoking login capabilities immediately.

Server Behavior & Self-Deactivation Guard:

- If an administrator attempts to deactivate their own account (`user == request.user`), the server returns HTTP 403 Forbidden: `{"code": "permission_denied", "message": "You cannot deactivate your own account."}`.
- For valid targets, transitions `is_active = False` and increments record `version`. Subsequent login attempts by this user are rejected with HTTP 400.

POST `/api/v1/auth/users/{id}/activate/` **PLATFORM ADMIN ONLY**

Restores an inactive user's login access. Transitions `is_active = True`.

5. Diagnostics & API Documentation

Method	Endpoint	Access	Response Schema & Purpose
GET	/api/v1/health/	Public	{"status": "ok", "service": "inchi-backend", "timestamp": "..."}
GET	/api/docs/	Public	Interactive OpenAPI 3.0 Swagger UI documentation. Allows browser-based execution.
GET	/api/schema/	Public	Raw YAML/JSON OpenAPI specification generated dynamically via drf-spectacular.